

Client-side topic

Klasa napada: CORS Vulnerabilities (Cross-Origin Resource Sharing)

Definicija klase: CORS je mehanizam bezbednosti pretraživača koji kontroliše koji domeni imaju dozvolu za pristup resursima na drugom domenu. Ranjivosti nastaju kada server pogrešno konfiguriše CORS politiku (obično preko HTTP **Access-Control-Allow-*** zaglavlja), dozvoljavajući neautorizovanim domenima da čitaju osetljive podatke koji pripadaju korisnicima.

Uticaj: Iskorištavanje CORS ranjivosti omogućava napadaču da izvuče osetljive informacije korisnika (npr. API ključeve, lične podatke, CSRF tokene) iz aplikacije kojoj žrtva pristupa. Ako je **Access-Control-Allow-Credentials** podešeno na **true**, napadač može izvršiti akcije u ime ulogovanog korisnika i ukrasti sesione podatke.

Uzroci ranjivosti:

1. **Poverenje u "Origin" zaglavlje:** Server slepo veruje Origin zaglavlju koje šalje pretraživač i automatski ga reflektuje u **Access-Control-Allow-Origin** odgovoru, umesto da koristi belu listu.
2. **Loša konfiguracija sa "null" vrednošću:** Server prihvata **Origin: null** ili dozvoljava pristup svima (*) dok su istovremeno omogućene kredencijale (**Access-Control-Allow-Credentials: true**).
3. **Nedostatak validacije:** Aplikacija ne proverava da li je dolazni zahtev zaista od poverenja pre nego što odobri deljenje resursa.

Kontramere:

1. **Implementacija bele liste (Allowlisting):** Umesto dinamičkog generisanja zaglavlja na osnovu korisničkog inputa, server treba da koristi strogu, prethodno definisanu listu dozvoljenih domena.
2. **Izbegavanje "wildcard" podešavanja:** Nikada ne koristiti **Access-Control-Allow-Origin: *** kada su u pitanju podaci koji zahtevaju autentifikaciju ili su osetljivi.
3. **Onemogućavanje "Credentials" ako nije nužno:** Ako aplikacija ne zahteva deljenje sesija sa drugim domenima, **Access-Control-Allow-Credentials** treba da bude **false** (ili izostavljeno).

4. **Validacija "Origin" zaglavlja:** Ako je dinamička provera neophodna, server mora striktno validirati Origin zaglavlje protiv unapred definisanih regex paterna pre nego što odgovori.